Compliance & Information Security

Security Starter Kit for Small Business

A practical, ready-to-adopt Information Security Policy and implementation guide, built around the NIST Cybersecurity Framework.

Document Type	Framework	Intended Use	Cost
Policy Template & Guide	NIST Cybersecurity Framework	Small & Independent Businesses	Free to Adopt & Customize

Contents

What's Inside This Kit

1 Why This Kit Exists 3

2 Information Security Policy 4

3 How to Adopt & Customize This Policy 6

4 What This Kit Doesn't Cover 7

5 Next Steps 7

1 Why This Kit Exists

Many small businesses know they should have formal security practices in place — for customer trust, cyber insurance requirements, or vendor and client due diligence — but don't know where to start, and can't always justify a full-time security hire or expensive consultant right away.

> A written Information Security Policy is often the foundation everything else is built on. It's frequently the first thing cyber insurance providers ask for, the first thing larger clients or vendors request during due diligence, and the first thing an auditor looks for as evidence of basic security governance.

This kit gives you a genuine starting point: a policy built around the same framework larger organizations use (the **NIST Cybersecurity Framework**), scaled down and written in plain language for business owners — not security professionals.

Who This Kit Is For

- Small businesses with no formal written security policy yet
- Businesses preparing for a cyber insurance application or renewal
- Businesses being asked by a client, partner, or vendor to show security documentation
- Anyone who wants a plain-language reference for good security habits

2 Information Security Policy

[Your Business Name] • Effective Date: [Insert Date] • Version 1.0

Purpose

This policy establishes the framework for protecting the business's information assets — including customer data, financial records, employee information, and business systems — from unauthorized access, disclosure, alteration, or destruction. It applies to all employees, contractors, and third parties who access company systems or data.

Scope

- Computers, servers, and mobile devices
- Cloud services and applications (email, file storage, accounting software, etc.)
- Physical records containing sensitive information
- Networks and connectivity (Wi-Fi, VPN, remote access)

Roles & Responsibilities

Role	Responsibility
Owner / Management	Approves policy, allocates resources, sets risk tolerance
IT / Security Lead (or outsourced provider)	Implements technical controls, monitors systems, responds to incidents
All Employees	Follow policy, report suspicious activity, complete required training

Access Control

- Access to systems and data is granted on a least-privilege, need-to-know basis
- Unique user accounts are required for all staff — no shared logins
- Access is reviewed at least annually and revoked immediately upon termination or role change

Data Protection

- Sensitive data (customer PII, payment information, financial records) is encrypted in transit and at rest where technically feasible
- Data is classified into at minimum two tiers — Public and Confidential — with handling rules for each
- Confidential data is not stored on personal devices or unapproved cloud services

Device & Endpoint Security

- All company devices use up-to-date antivirus/anti-malware protection
- Operating systems and software are patched within 30–90 days of release, prioritized by severity
- Devices are locked or logged off when unattended

Password & Authentication

- Passwords meet minimum complexity requirements, or use passphrase-based policies
- Multi-factor authentication (MFA) is required for email, financial systems, and any system storing confidential data

Network Security

- Business Wi-Fi networks use WPA2/WPA3 encryption at minimum
- Guest networks are segregated from business networks
- Remote access requires a VPN or equivalent secure connection

Incident Response

All suspected security incidents (lost devices, phishing clicks, unauthorized access) are reported to a designated contact within 24 hours.

Security Awareness

- All employees complete security awareness training upon onboarding and annually thereafter
- Phishing simulation exercises are conducted periodically to reinforce training

Third-Party & Vendor Management

- Vendors with access to confidential data are assessed for security practices before onboarding
- Data processing agreements are used where applicable (e.g., under privacy regulations like PIPEDA/GDPR)

Compliance, Enforcement & Review

Violations of this policy may result in disciplinary action and may carry legal or regulatory consequences depending on the nature of the violation. This policy should be reviewed at least annually, or following a significant security incident or change in business operations.

3 How to Adopt & Customize This Policy

This policy is a starting template, not a plug-and-play finished document. To make it your own:

1. **Fill in the bracketed fields** — business name, effective date, and your designated incident contact.
2. **Adjust the specifics to match reality.** If you don't currently require MFA everywhere listed, either implement it or note a target date to get there — a policy should describe what you actually do, not just what sounds good.
3. **Have it reviewed by whoever handles your IT** (in-house or outsourced) to confirm the technical statements match your actual environment.
4. **Get sign-off from ownership/management** and communicate it to your team — a policy that nobody has read isn't doing its job.
5. **Revisit it at least yearly**, or any time your business changes significantly (new software, new locations, a security incident).

A Note on Industry-Specific Requirements

This template covers general best practices, but many industries carry additional obligations:

Industry	Additional Consideration
Healthcare / Dental	Patient health information handling (e.g., PHIPA in Ontario, HIPAA in the U.S.)
Retail / E-commerce	Payment card data handling (PCI DSS)
Professional services	Client confidentiality and data-sharing agreements
Any business handling personal data	Privacy law obligations (PIPEDA in Canada, GDPR if serving EU customers)

4 What This Kit Doesn't Cover

Being upfront about the limits of a template like this is part of using it responsibly:

- It is **not a substitute for a tailored risk assessment** of your specific systems, data, and threats.
- It does **not guarantee compliance** with any specific regulation or insurance requirement on its own — those typically require documented evidence that the policy is actually being followed.
- It is **not legal advice.** If you're navigating specific regulatory obligations, consult a qualified professional in that area.
- It does **not replace an incident response plan, backup/disaster recovery plan, or vendor risk assessment** — these are natural next documents once this policy is in place.

> This document is provided as a free educational resource to help small businesses take a first, informed step toward better security practices.

5 Next Steps

Once this policy is filled in, reviewed, and adopted, consider building on it with a few natural follow-on documents:

- **Acceptable Use Policy** — rules for how employees use company devices, networks, and accounts
- **Incident Response Plan** — step-by-step actions to take when something goes wrong
- **Data Backup & Retention Policy** — how long data is kept and how it's recovered if lost

Revisit this policy at least once a year, or any time your business, tools, or team change significantly.

A Living Document

Security is not a one-time checklist — it's an ongoing habit. This kit is a starting point, not a finish line.